

Daily QA & Security Work Report

Date: 2026-04-22 **Prepared by:** Perumal **Branch:** login_flow_test_21_04_2026 **App:** Hima (Android)

1. Summary

Today I ran a full QA + security pass of the Hima Android **Edit Profile** and **Voice Verification** screens across three testing tracks (API testing, UI automation, user-perspective testing), executed 64 automated test cases plus a full manual walkthrough, uncovered 17 bugs (4 S1 Critical, 4 S2 High, 7 S3 Medium, 2 S4 Low), and landed client-side fixes on branch `login_flow_test_21_04_2026` for every bug that has a meaningful client-side mitigation. Bugs whose root cause is server-side are fully documented for the backend team.

Branch status: all fixes compiled cleanly with `./gradlew :app:compileDevelopmentDebugKotlin` and were verified by re-running the automated suite (static 12/12 PASS, live voice 10/10 PASS). Manual on-device testing by me confirmed the HTML-in-toast bug was real and that the client sanitizer now replaces the HTML with "Please try again later" exactly as intended. No push to `main` — pending senior review.

2. Testing Performed

2.1 API Testing

Black-box API testing against the dev backend (`https://demohima.himaapp.in/api/auth`) using a Python test harness that drives `urllib` directly — independent of the Android client. Positive, validation, security, boundary and performance cases per endpoint.

- Exercised 5 endpoints: `/user_validations`, `/avatar_list`, `/update_profile`, `/speech_text`, `/update_voice`.
- Confirmed **IDOR on three mutating endpoints**: `/user_validations`, `/update_profile`, `/update_voice` all accept a foreign `user_id` in the request body instead of deriving it from the JWT subject (BUG-EP-005, BUG-EP-010, BUG-VV-006). The `/update_voice` IDOR was proven with a real overwrite of another user's voice recording.
- Confirmed `/avatar_list` and `/speech_text` are reachable without authentication at all (BUG-EP-008, BUG-VV-002).
- Confirmed `/update_profile` crashes to HTTP 500 HTML on the second name change and on 30-interest payloads, instead of returning JSON errors (BUG-EP-015, BUG-EP-013).
- Confirmed `/update_profile` accepts missing `name` field — blanks out the display name (BUG-EP-012).
- Confirmed `/update_voice` accepts a 10 MB file with no size or MIME cap server-side (BUG-VV-008); server does reject WAV in favour of MP3 (VV-UV-11 positive case).
- Total cases executed: **42**. Artifacts: `QA_Reports/automation/edit_profile_voice_api_tests.py` (source, reproducible) and `QA_Reports/automation/Hima_EditProfile_Voice_API_Report.pdf`.

2.2 UI Automation Testing

Scripted UI automation driven via `adb shell input` and `uiautomator dump`, plus a deterministic static analyser parsing the layout XML and activity Kotlin source for standard Android UX and performance anti-patterns.

- **Voice Verification (live UI on emulator-5554)**: 10 test cases — all PASS. Verified the new 30-second auto-stop fix works on device by holding the mic button past the cap (V-06), verified rapid-tap resilience (V-07), and verified graceful handling under airplane mode (V-10).
- **Edit Profile (static UI + code analysis)**: 12 checks covering `maxLength`, `inputType`, accessibility labels, button-disabled-while-loading, text-watcher debouncing, `SharedPreferences` reads on scroll, unsaved-edits guard, `Html.fromHtml` on name fields, interests cap, and observer wiring. Initial run surfaced 5 failures (E-04, E-05, E-06, E-07, E-08). All 5 fixed in the same session; re-run shows **12/12 PASS**.

- Why static for Edit Profile: the test account (mobile 9876543210) fell into the terminal “Almost done — under review” state for female creators during API testing, blocking navigation to the home screen. Static analysis caught the same category of issues a live Espresso pass would.
- Total automated cases: **22**. Artifacts: `QA_Reports/ui_automation/run_voice_tests.py`, `QA_Reports/ui_automation/run_edit_profile_static.py`, `QA_Reports/ui_automation/Hima_UI_Automation_Report.pdf`.

2.3 User-Perspective Testing

Hands-on walkthrough on the emulator after the fixes were compiled, following the manual test plan (E-05, E-06, E-07, E-08 sub-cases A–D, E-04 TalkBack, R-1 to R-5 regression smoke).

- Confirmed on device that the 30-second voice auto-stop fix behaves correctly (matches V-06).
- Confirmed the Update button disable, debounced validation, unsaved-edits dialog, and accessibility label all behave as designed.
- **Caught a new bug during manual testing:** entering certain names (e.g. “imabiu”) caused the app to display a raw Laravel `<!DOCTYPE html> 500` error page inside the in-field toast and hint text (UI-BUG-001). Logcat evidence captured; the Android side has been fixed defensively (sanitizer filters any non-user-friendly server response), and the underlying server crash has been raised as BUG-EP-017 for the backend team.
- Observed 7 repeated HTTP 500 responses on `/user_validations` within 20 seconds with no server-side throttling — raised as BUG-EP-018.
- Regression smoke passed on all remaining paths; the user confirmed “all other tests are fine, only the HTML error was new”.

3. Bug Status — All 17 Defects

Status legend: *Fully fixed* (client-side change complete, no backend dependency), *Partially fixed* (client-side mitigation landed, backend fix still required for full remediation), *Documented* (no meaningful client-side action possible — backend fix required).

ID	Title	Severity	Status
BUG-EP-005	IDOR on /user_validations — accepts foreign user_id	S1 Critical	Documented
BUG-EP-010	IDOR on /update_profile — can overwrite another user's profile	S1 Critical	Documented
BUG-EP-015	/update_profile returns HTTP 500 HTML on second name change	S1 Critical	Documented
BUG-VV-006	IDOR on /update_voice — verified overwriting of another user's voice	S1 Critical	Documented
BUG-EP-012	/update_profile accepts missing name field (wipes display name)	S2 High	Documented
BUG-EP-017	/user_validations returns HTML 500 Server Error page for certain accounts	S2 High	Documented
BUG-VV-002	/speech_text reachable without authentication	S2 High	Documented
UI-BUG-001	Edit Profile toast renders raw HTML error pages from server	S2 High	Partially fixed
E-05	Update button remains tappable during /update_profile request (double-fire)	S3 Medium	Fully fixed
E-06	Name field fires /user_validations on every keystroke (no debounce)	S3 Medium	Fully fixed
E-07	updateButton() reads SharedPreferences on every avatar scroll tick	S3 Medium	Fully fixed
BUG-EP-008	/avatar_list reachable without authentication	S3 Medium	Documented
BUG-EP-013	/update_profile accepts 30 interests (client caps at 5)	S3 Medium	Documented
BUG-EP-018	No rate limit on /user_validations (7+ crashes logged in 20 s)	S3 Medium	Documented
BUG-VV-008	/update_voice accepts 10 MB upload with no size/MIME cap	S3 Medium	Partially fixed
E-04	Back icon (cv_back) missing accessibility contentDescription	S4 Low	Fully fixed
E-08	Back press on Edit Profile discards unsaved edits silently	S4 Low	Fully fixed

Totals: 5 fully fixed, 2 partially fixed, 10 documented for backend fix.

4. Client-Side Changes Landed Today

4.1 Voice Verification — 30-second auto-stop (Fully fixed)

- Reduced `CountDownTimer` window from **1 hour** (`60 * 60000 ms`) to **30 seconds** in `BottomSheetVoiceIdentification.kt`.
- Implemented `onFinish()` (previously empty) so the recording auto-stops, shows a “Max 30 seconds” toast, clears the ripple animation, and routes through the existing `stopRecording(false)` path so the Submit / Play / Re-record buttons appear exactly as they would on a normal release.
- Verified on device (V-06) and on emulator: a 32-second press auto-stops at 30 s and the review UI appears.

4.2 Voice Upload — explicit MIME + 5 MB client guard (Partially fixed)

- `VoiceIdentificationActivity.kt` now passes `asRequestBody("audio/mpeg".toMediaTypeOrNull())` so the server receives the correct Content-Type header instead of the previous empty / octet-stream default.

- Client rejects any recording above 5 MB with a user-facing toast (“Recording too large, please re-record”) and deletes the file to reclaim storage.
- Null / zero-byte files are also rejected before the upload call.

Backend still required: the server currently accepts a 10 MB payload (BUG-VV-008). Server must enforce `'voice' => 'file|mimes:mp3|max:10240'` plus an nginx `client_max_body_size` guard — curl users bypass any client cap.

4.3 Edit Profile — 5 UI fixes in a single activity (Fully fixed)

- **E-04:** added `android:contentDescription="@string/back"` and `clickable/focusable=true` on `cv_back`; moved accessibility responsibility off the inner `iv_back` `ImageView`. TalkBack now announces “Back, button” instead of “Unlabeled button”.
- **E-05:** `binding.btnUpdate.isEnabled = false` added at the moment the loader appears; re-enabled in both the success and error observer paths. Double-tapping the Update button no longer fires two `/update_profile` calls.
- **E-06:** name validation now uses `Handler.postDelayed` with a 300 ms debounce and `removeCallbacks` on each keystroke. Typing "Aravindan" fires exactly **one** call to `/user_validations` instead of nine.
- **E-07:** cached `originalUserName`, `originalAvatarId`, `originalInterestsList`, and `cachedUserId` in `onCreate()`. Removed the `getPrefs().getUserData()` call from `updateButton()` so no `SharedPreferences` read happens on every avatar scroll tick.
- **E-08:** both the back icon (`cv_back`) and the system back key (`onBackPressedDispatcher`) now check `hasUnsavedChanges()` and show an `AlertDialog` (“Discard / Keep editing”) when the user has modified the name, avatar, or interests. Added 3 strings to `strings.xml`.
- Added `onDestroy()` to remove any pending debounce runnable, avoiding a handler leak.

4.4 Edit Profile — UI-BUG-001 HTML-in-toast sanitizer (Partially fixed)

- Added a private helper `safeServerMessage(raw: String?)` in `EditProfileActivity.kt`. It returns the generic “Please try again later” fallback whenever the server's response message starts with `<`, contains `<!doctype /` `<html /` `<body`, mentions “stack trace” or “exception in”, or exceeds 160 characters.
- Wired in 3 places: the name-validation success-false observer (toast + hint `TextView`), the name-validation error observer, and the update-profile failure toast.
- Logcat during manual re-test confirmed the sanitizer is working: “userValidationLiveData received: success=false, message=<!DOCTYPE html>...” is followed by “Displaying error message: Please try again later” on the very next line.

Backend still required: the server should never return HTML to an API route. Laravel's exception handler must return `{"success":false,"message":"..."}` JSON for every throwable on `api/*` routes (tracked as BUG-EP-017).

5. Documented-Only Bugs (backend fix required)

These bugs have no meaningful client-side mitigation — the root cause is on the server. They are captured in the API test report with repro steps, proofs, and recommended fixes for the backend team.

- **BUG-EP-005** — `/user_validations`: derive user id from JWT sub; stop trusting body `user_id`.
- **BUG-EP-008** — move `/avatar_list` behind the `auth:api` middleware group.
- **BUG-EP-010** — `/update_profile`: same IDOR fix pattern; use `$request->user()->id`, never body `user_id`.
- **BUG-EP-012** — add FormRequest `'name' => 'required|string|min:4|max:10'`; return JSON 400 instead of silently accepting empty.
- **BUG-EP-013** — add `'interests' => 'array|max:5|in:Politics,Art,...'` so the server enforces what the UI already limits to 5.
- **BUG-EP-015** — the “change name only once” rule currently throws an uncaught exception on the second call. Wrap in a validator / try-catch and return JSON `{"success":false,"message":"You can change your name only once."}`.
- **BUG-EP-017** — `/user_validations` returns HTML 500 for `user_id=456976` (reproducible on our test mobile). Fix the underlying exception and ensure the exception handler returns JSON on `api/*` routes.
- **BUG-EP-018** — add Laravel `throttle:30,1` middleware on `/user_validations`; 7 crashing requests in 20 s all hit the server with no back-off.
- **BUG-VV-002** — `/speech_text` must require JWT; voice prompts are currently scrapable without auth.
- **BUG-VV-006** — `/update_voice` IDOR: same fix pattern. Voice is the gating step for female creator verification, so this is account-takeover-adjacent.

6. Files Changed on Branch

File	Change
<code>app/src/main/java/com/gmwapp/hima/activities/VoiceIdentificationActivity.kt</code>	Explicit audio/mpeg MIME on voice upload; 5 MB client-side size guard; safer null/empty file handling.
<code>app/src/main/java/com/gmwapp/hima/dialogs/BottomSheetVoiceIdentification.kt</code>	CountDownTimer reduced 1 hour → 30 seconds; <code>onFinish()</code> now auto-stops the recording and shows a toast.
<code>app/src/main/res/layout/activity_edit_profile.xml</code>	Added <code>contentDescription=@string/back</code> + <code>clickable/focusable</code> on <code>cv_back</code> ; moved accessibility away from inner icon.
<code>app/src/main/res/values/strings.xml</code>	Added strings: <code>discard_changes_message</code> , <code>discard</code> , <code>keep_editing</code> .
<code>app/src/main/java/com/gmwapp/hima/activities/EditProfileActivity.kt</code>	5 fixes: (E-05) Update button disabled while request in flight; (E-06) 300 ms debounce on name validator; (E-07) cached <code>originalName</code> / <code>originalAvatarId</code> / <code>interests</code> / <code>userId</code> in <code>onCreate</code> — no more prefs reads on scroll; (E-

File	Change
	08) unsaved-edits AlertDialog on cv_back click and onBackPressedDispatcher; (UI- BUG-001) safeServerMessage() sanitizer — filters HTML / stack traces / overlong server strings before display.

All changes compile cleanly: `./gradlew :app:compileDevelopmentDebugKotlin` → **BUILD SUCCESSFUL**. Only pre-existing deprecation warnings remain (e.g. `statusBarColor`), none introduced by today's edits.

7. Work Attribution — What I Did vs What Claude Assisted With

Being transparent about tooling: AI assistance (Claude Code) was used for code analysis, bug explanation in simple language, harness scaffolding, and executing edits under my direction. All testing, judgment calls, device validation, and the QA report content are my own.

7.1 Done by me (Perumal)

- Scoped the two target screens (Edit Profile, Voice Verification) and the testing tracks to run today.
- Ran the full manual on-device walkthrough after each set of fixes — verified the 30-second voice auto-stop, the debounced name validation, the unsaved-edits dialog, and the accessibility label behaviour on a real emulator.
- **Caught the HTML-in-toast bug personally during manual testing** (the one the automated suites missed) and captured the logcat evidence that proved the server was returning Laravel's stock 500 page.
- Captured proof: before/after screenshots, adb logcat transcripts, curl probes of the dev backend, and the UI dumps backing each automation case.
- Decided which 5 + 1 bugs had meaningful client-side mitigations and which 10 must go to the backend team; chose severity per bug.
- Reviewed every code change before it landed on the branch; confirmed compile success before running regression.
- Kept the branch local (no push to `main`) pending senior review.

7.2 Used Claude for

- Built the Python API test harness against the dev backend (`edit_profile_voice_api_tests.py` , 42 cases) under my direction — I defined the endpoints, payloads, and assertions.
- Built the adb+uiautomator UI automation driver and the Voice live test suite (`run_voice_tests.py` , 10 cases) and the Edit Profile static analyser (`run_edit_profile_static.py` , 12 cases).
- Plain-language explanations of each bug (what's wrong, why it matters, how to fix) for the tech-lead-facing PDF.
- Code edits for the 6 client-side fixes (voice MIME+size, 30s cap, E-04 to E-08, UI-BUG-001 sanitizer) under my direction; I dictated the approach and reviewed the diff.
- Generated the two PDF reports (`Hima_EditProfile_Voice_API_Report.pdf` , `Hima_UI_Automation_Report.pdf`) and this daily report via Chrome headless HTML-to-PDF.
- Cross-checking that the regex for the HTML sanitizer covered `<!DOCTYPE` , `<html` , `<body` , and overlong server payloads — nothing slips through.

8. Pending / Asks for Senior & Backend

- **Backend pickup of 10 documented-only bugs:** BUG-EP-005, 008, 010, 012, 013, 015, 017, 018 and BUG-VV-002, 006. All have specific repro steps and one-line suggested fixes in the API report.
- **Reset / fresh test account** so QA can resume driving through MainActivity — mobile 9876543210 is currently stuck on the “Almost done—under review” terminal screen.
- **Senior approval** to add the 6 client-side fixes to the existing login-flow branch, or to cut a separate PR for the Edit Profile / Voice Verification work.
- **Prioritisation** of BUG-EP-010 and BUG-VV-006 — both are critical IDORs that allow account-takeover-adjacent tampering (profile overwrite and voice replacement of another user).
- **Approval** to push `login_flow_test_21_04_2026` to the remote and open a PR that includes both yesterday's login-flow work and today's Edit Profile / Voice Verification fixes.

9. Artifacts

- `QA_Reports/automation/edit_profile_voice_api_tests.py` — reproducible API test suite (42 cases).

- `QA_Reports/automation/edit_profile_voice_report.html` and `Hima_EditProfile_Voice_API_Report.pdf` — API test report (interactive HTML + tech-lead PDF).
- `QA_Reports/automation/edit_profile_voice_results.json` — raw results JSON for auditability.
- `QA_Reports/ui_automation/run_voice_tests.py` — live UI automation driver (adb + uiautomator) for the Voice Verification screen.
- `QA_Reports/ui_automation/run_edit_profile_static.py` — static UI + code analyser for Edit Profile (12 checks).
- `QA_Reports/ui_automation/ui_driver.py` — shared adb/uiautomator helper used by the voice suite.
- `QA_Reports/ui_automation/ui_automation_report.html` and `Hima_UI_Automation_Report.pdf` — UI automation report with embedded screenshots.
- `QA_Reports/ui_automation/screenshots/` — before/after PNGs per voice test case; includes `almost_done_blocked.png` evidence of the blocked-account state.
- `QA_Reports/ui_automation/logs/` — logcat slice per voice test case.
- `QA_Reports/Daily_Report_2026-04-22.pdf` — this report.

End of report — 2026-04-22